ISO 27001 導入專案：第一階段 - 啟動與範圍定義問卷

致：專案推動小組 (IST)、高階管理階層 (MGMT)、IT 部門、人資部門及其他相關部門主管

問卷目的：本問卷旨在協助 ISO 27001 導入，收集貴公司關於組織背景、營運現況、法規遵循要求以及對於資訊安全管理系統 (ISMS) 期望範圍的初步資訊。這些資訊將作為我們共同定義 ISMS 導入範圍、確認專案目標、識別利害關係人及其要求，並規劃後續輔導活動的重要基礎。

請相關部門代表協助填寫，並盡可能提供詳細與準確的資訊。您的詳盡回覆將有助於專案的順利啟動與範圍的精準界定。如有任何疑問，請隨時與輔導顧問聯繫。

第一部分：專案啟動與高階管理層支持

主要目標：確認導入範圍、目標與高階支持，建立專案基礎。關鍵成果：清晰的 ISMS 保護邊界、專案正式啟動。

1. 專案啟動與期望：

- 貴公司期望透過導入 ISO 27001 資訊安全管理系統，達成哪些主要的營運目標或解決哪些目前面臨的資訊安全相關挑戰？
    - 引導範例：
        - 希望提升客戶對我們數據處理的信任度，以爭取更多國際訂單。
        - 目前資安事件頻傳，希望能系統化降低資安風險，減少營運中斷。
        - 為符合特定行業法規要求（如金融、醫療），必須取得國際資安驗證。
        - 優化內部資訊安全流程，提升員工資安意識，減少人為錯誤。
- 對於本次 ISO 27001 導入專案的成功，貴公司有哪些具體的期望或可衡量的指標？
    - 引導範例：
        - 在 2025 年 Q1 前成功取得 ISO 27001 證書。
        - 資訊安全事件數量在導入後一年內降低 30%。
        - 員工資安意識測驗平均分數提升 20%。
        - 滿足所有重要客戶合約中關於資安條款的要求。
        - 提升企業在供應鏈中的資安評級。
- 在專案啟動初期，是否有任何已知的專案限制（如預算、時程、資源）、假設或潛在風險需要特別提出？
    - 引導範例：
        - 專案預算有限，需優先投入於核心系統保護。
        - IT 部門目前人力吃緊，部分任務可能需要外部支援。
        - 關鍵資料位於雲端，可能需要額外溝通雲端服務商的資安責任界線。
        - 高階主管的時間安排較困難，需提前協調會議時間。

2. 高階管理層的承諾與參與:

- 請簡述高階管理階層 (MGMT) 對於導入並支持資訊安全管理系統的承諾程度與具體期望。
    - 引導範例:
        - 董事長已在內部會議中多次強調資安的重要性, 並承諾提供足夠資源。
        - 總經理明確指出, ISO 27001 驗證是公司今年度的首要戰略目標之一。
- 高階管理階層預計如何參與本專案的推動？
    - 引導範例:
        - 定期參與管理審查會議, 審閱資安政策與風險處理計畫。
        - 在全員大會上公開宣示對資安專案的支持, 激勵員工參與。
        - 核准必要的預算、人力與時間投入。
        - 必要時協助排解跨部門資源或權責衝突。
- 高階管理階層指派的 ISMS 推動小組 (IST) 召集人或主要負責人是哪一位？

3. 引導問題(內部與外部因素分析):

- 在我們深入探討具體細節之前, 請貴公司思考並簡述, 目前有哪些主要的 內部因素 (例如:組織文化、現有技術架構的優劣勢、員工技能、可用資源、內部溝通效率等) 及外部因素 (例如:市場競爭態勢、新興技術威脅、供應鏈依賴性、產業特殊法規環境變化、客戶要求等) 可能會對貴公司資訊安全管理系統的成功建置與達成預期成果造成正面或負面影響？
    - 引導範例:
        - 內部正面因素: 公司文化開放, 員工樂於接受新知;IT 部門技術能力強。
        - 內部負面因素: 部分老舊系統汰換不易;跨部門溝通有待加強。
        - 外部正面因素: 產業鏈上游廠商普遍要求 ISO 27001, 有利於我們獲取業務。
        - 外部負面因素: 新興網路攻擊手段不斷演進, 防禦壓力大;國際法規變動快速。

第二部分:組織、營運、法規訪談與資料收集

IT 主要任務/配合事項: 提供現有 IT 基礎架構概況 (網路拓樸、伺服器、雲端服務、主要系統清單)。說明目前 IT 維運與資安管理作法 (若有)。預期 **IT** 產出/貢獻: IT 架構圖 (高階)、系統清單、雲端服務列表、現有 IT 管理作法說明。

A. 組織與營運概況

1. 公司基本資料:

- 請提供貴公司的最新組織架構圖。
- 請簡述貴公司的主要業務活動、核心產品或服務項目。
- 貴公司的主要營運據點有哪些(請列出地址)？員工人數大約多少？

- 是否有海外分支機構或遠端工作人員？若有，其營運模式為何？

2. 核心營運流程與資訊資產：

- 請簡要描述貴公司幾個核心的業務流程（例如：研發、生產、銷售、客戶服務、財務等），並說明這些流程中主要處理的資訊類型。
- 在這些流程中，貴公司認為最重要的資訊資產有哪些？（例如：客戶資料庫、產品設計圖、財務報表、員工個人資料、系統原始碼、營運關鍵系統設定等）。針對這些重要資產，請初步評估其對業務營運的重要性等級（如：極高、高、中、低），或當其機密性、完整性或可用性受損時，可能對公司造成的衝擊程度為何？

    - 引導範例：
        - 客戶資料庫：極高，機密性與可用性受損將導致客戶流失、法規罰款。
        - 產品設計圖：高，機密性受損將造成研發成果洩露，影響競爭力。
        - **ERP** 系統：極高，可用性受損將導致公司營運全面停擺。
- 目前是否有針對這些重要資訊資產進行盤點或分類分級？

3. 資訊科技 **(IT)** 環境（請 **IT** 部門填寫）：

- 請 IT 部門簡述主要的資訊系統架構，包括：

    - 主要的網路環境拓樸（內部網路、對外網路、無線網路、VPN 等）。
    - 主要的伺服器類型與作業系統（實體伺服器、虛擬化平台如 VMware/Hyper-V、容器平台如 Docker/Kubernetes 等）。
    - 核心的應用系統或平台（如 ERP、CRM、郵件系統、檔案伺服器、人資系統、自有開發系統等）。
    - 資料庫的類型與用途（如 MSSQL, MySQL, Oracle, MongoDB 等）。
- 目前是否有委外廠商協助 IT 維運、系統開發或資安防護？若有，其服務範圍與合約內容為何？
- 貴公司是否有使用雲端服務（如 IaaS, PaaS, SaaS）？若有，是哪些服務（例如：AWS, Azure, Google Cloud, Microsoft 365, Salesforce, Box, Slack 等）以及主要儲存或處理的資料類型為何？

4. 人力資源 **(HR)** 作業（請人資部門填寫）：

- 請人資部門說明員工任用、報到、試用期、職務異動、離職等相關作業流程中，涉及資訊存取權限申請、變更與取消的現行做法。
- 目前是否有針對員工（包含新進、在職、離職員工及外部人員）的資訊安全認知、保密協定或相關規範的宣導、教育訓練或協議簽署？

5. 供應鏈與第三方關係：

- 貴公司是否有重要的供應商、委外廠商、顧問或合作夥伴，其作業流程與貴公司的資訊系統或敏感資訊有存取、交換或處理的關係？
- 與這些第三方單位在資訊交換、系統介接或服務提供方面，目前有哪些安全控管措施或協議？

B. 法規、合約與其他要求

1. 法律與法規遵循:

- 貴公司的營運活動(包含產品或服務)是否受到特定資訊安全或個人資料保護相關法律法規的規範?(例如:中華民國《個人資料保護法》及其施行細則、《營業秘密法》、《資通安全管理法》(若適用)等, 或其他國家/地區的法規如 GDPR、CCPA 等)請列舉。
- 針對上述法規, 目前是否有專責人員或部門負責追蹤、解讀法規要求並確保遵循?
- 過去是否有發生過因違反相關法規而受到主管機關調查或處罰的事件?

2. 合約要求:

- 貴公司與客戶、供應商或其他合作夥伴簽訂的合約中, 是否有關於資訊安全、資料保護或保密責任的特定條款或要求?
- 若有, 請簡述這些要求的重點內容或提供相關條款範本。

3. 其他利害關係方要求:

- 請識別並列出貴公司的主要內部利害關係人(例如:股東、董事會、各部門主管、員工等)與外部利害關係人(例如:客戶、供應商、合作夥伴、主管機關、產業公會、母公司等)。針對每一利害關係人, 請說明其在資訊安全方面的具體要求、期望、合約義務或關注重點為何?
    - 引導範例:
        - 客戶: 期望我們能保護其交易數據、個人資料, 並通過第三方資安審計。
        - 主管機關 **(**如金管會**)**: 要求符合金融行業的資安規範, 定期提交資安報告。
        - 員工: 期望公司提供安全的辦公環境, 並明確告知資安責任與操作規範。

第三部分:**ISMS** 範圍草案擬定與討論

1. ISMS 驗證範圍初步構想:

- 根據目前的理解與討論, 貴公司初步希望將哪些 部門**/**單位 納入 ISO 27001 的驗證範圍?
    - 引導範例: 總經理室、資訊部、研發部、業務部、財務部、人資部。
- 希望納入的 業務流程**/**活動 有哪些?
    - 引導範例: 資訊系統開發與維運、客戶資料處理、財務會計作業、人力資源管理、銷售與訂單處理、雲端服務管理。
- 希望納入的 實體位置 (例如:總公司地址、特定樓層、機房、分公司等)有哪些?
    - 引導範例: 總公司辦公室(XX市XX區XX路XX號X樓)、機房A(位於總公司X樓)、雲端服務平台(如 AWS 台灣區域)。
- 希望納入的 資訊系統**/**網路環境 有哪些?

    - 引導範例：ERP 系統、CRM 系統、郵件伺服器、檔案伺服器、研發伺服器、公司內部網路、無線網路、與第三方系統介接的 API 平台。
- 是否有任何明確 不打算 納入本次 ISMS 驗證範圍的部門、流程、位置或系統？若有，請詳細說明排除的主要業務理由或技術理由，並初步評估此排除對於整體資訊安全風險的潛在影響，以及與納入範圍部分之間可能存在的介面與管理需求為何？

    - 引導範例：
        - 排除原因：某些非核心業務部門或實體據點，目前資安風險較低，且業務性質單純，為節省初期導入成本與時間而暫時排除。
        - 潛在影響與介面：需考慮這些排除部分與範圍內部門/系統之間的資料交換或人員互動，確保其介面處仍有足夠的資安管控。例如，排除的部門仍需遵守公司的基本資安政策，並注意與核心系統互動時的資料保護。

2. 選擇該範圍的理由與考量：

- 選擇上述初步範圍的主要考量是什麼？

    - 引導範例：保護公司最核心的資訊資產、符合特定客戶的合約要求、降低特定業務流程的資安風險、提升特定部門的資安水平、符合特定法規要求。
- 此初步範圍是否能有效地涵蓋貴公司認為最重要或風險最高的資訊資產與業務活動？

3. 範圍邊界的界定：

- 對於初步構想的範圍，其邊界（例如：與範圍外部門/系統的介面、資料流向等）是否清晰可辨識？
- 在實務上，如何區分範圍內與範圍外的網路、系統、人員及其實體區域？

第四部分：**ISMS** 範圍最終確認與核准

1. 範圍確認的考量因素：

- 在最終確認 ISMS 範圍時，貴公司認為有哪些關鍵因素需要被納入考量？

    - 引導範例：導入成本、預期效益、資源可行性、專案時程、管理階層的策略方向、客戶的急迫要求、市場競爭壓力。
- 對於 ISMS 範圍的劃定，是否有任何已知的限制因素或必須滿足的條件？

2. 範圍核准流程：

- 貴公司內部對於 ISMS 這樣管理系統的範圍，其最終的核准權責單位或人員是誰？（例如：總經理、執行長、董事會等）
- 預計何時可以完成 ISMS 範圍的內部討論並取得最終核准？

問卷填寫說明：

- 請盡可能提供完整和具體的資訊。若某些問題的答案需要跨部門協調，請先進行內部討論以凝聚共識。
- 若有相關佐證文件（如組織圖、現行政策文件、網路架構圖、法規清單、合約範本等），可作為附件提供，或於後續訪談時出示。
- 本問卷收集的所有資訊將被嚴格保密，僅用於本次ISO 27001 導入專案之規劃與執行。

預計回收日期：[請公司填寫]

感謝您的詳細填寫與合作！這將對專案的成功至關重要。

輔導顧問聯絡方式：顧問姓名/公司：[請填寫顧問姓名/公司名稱] 聯絡電話：[請填寫顧問聯絡電話] 電子郵件：[請填寫顧問電子郵件]